

TryHackMe - ItsyBitsy

<https://tryhackme.com/room/itsybitsy>



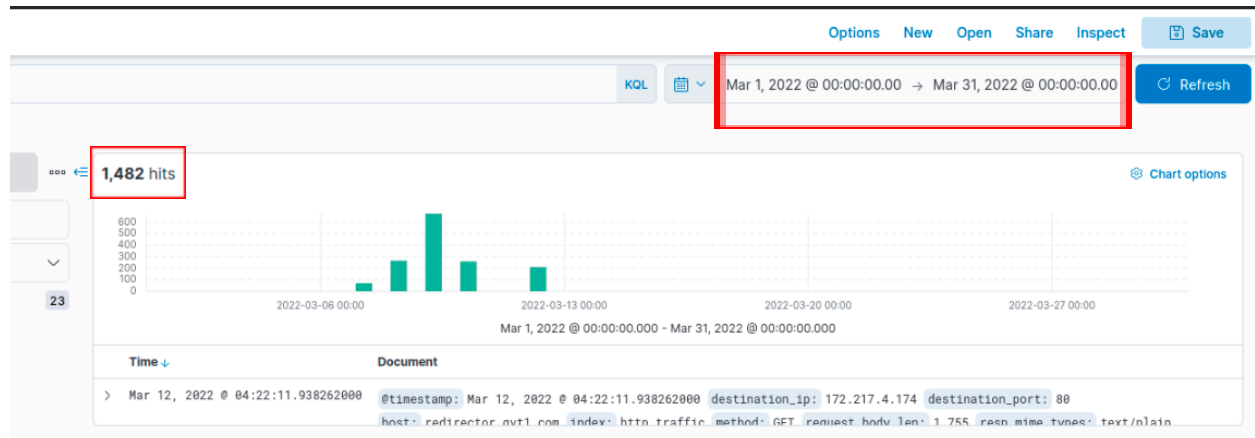
Scenario

During normal SOC monitoring, Analyst John observed an alert on an IDS solution indicating a potential C2 communication from a user Browne from the HR department. A suspicious file was accessed containing a malicious pattern THM:{ _____ }. A week-long HTTP connection logs have been pulled to investigate. Due to limited resources, only the connection logs could be pulled out and are ingested into the connection_logs index in Kibana.

Phase 1: Initial Triage & Anomaly Detection

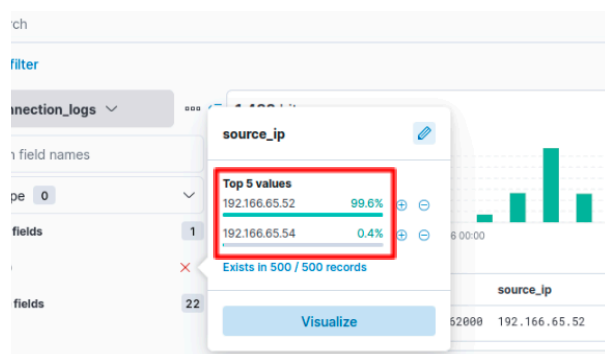
1. How many events were returned for the month of March 2022?

- **Answer:** 1482
- **Methodology:** Setting the Kibana Discover timeframe from Mar 1, 2022 to Mar 31, 2022 and querying the `connection_logs` index reveals a baseline of 1,482 total connection events for the month.



2. What is the IP associated with the suspected user in the logs?

- **Answer:** 192.166.65.54
- **Methodology:** To find the anomaly, we analyze the `source_ip` field. The visualization shows that 192.166.65.52 generates 99.6% of the traffic, representing normal baseline behavior.



- However, **192.166.65.54** accounts for only 0.4% of the traffic, making it highly suspicious and our primary target for investigation.

⊕ ⊖ 🔍 🔄	# response_body_len	5
⊕ ⊖ 🔍 🔄	📄 source_ip	192.166.65.54
⊕ ⊖ 🔍 🔄	# source_port	53,249
⊕ ⊖ 🔍 🔄	# status_code	200
⊕ ⊖ 🔍 🔄	📄 status_msg	OK
⊕ ⊖ 🔍 🔄	📅 timestamp	Mar 10, 2022 @ 11:23:11.924911000
⊕ ⊖ 🔍 🔄	📄 uid	C8D20I2ggQSCXNNZn7
⊕ ⊖ 🔍 🔄	📄 uri	/yTg0Ah6a
⊕ ⊖ 🔍 🔄	📄 user_agent	bitsadmin
⊕ ⊖ 🔍 🔄	# version	3.2

Phase 2: Identifying the Attack Vector (LOLBins)

3. The user's machine used a legit windows binary to download a file from the C2 server. What is the name of the binary?

- **Answer:** **bitsadmin**
- **Methodology:** By pivoting our search to isolate traffic originating *only* from the suspected IP (**source_ip: 192.166.65.54**), we can inspect the specific HTTP requests. Expanding the log details reveals the **user_agent** field is populated with **bitsadmin**. Attackers frequently use Bitsadmin as a Living-Off-The-Land Binary (LOLBin) to download malicious payloads because it is a trusted, native Windows tool that often bypasses initial firewall and antivirus checks.

⊕ ⊖ 🔍 🔄	# response_body_len	5
⊕ ⊖ 🔍 🔄	📄 source_ip	192.166.65.54
⊕ ⊖ 🔍 🔄	# source_port	53,249
⊕ ⊖ 🔍 🔄	# status_code	200
⊕ ⊖ 🔍 🔄	📄 status_msg	OK
⊕ ⊖ 🔍 🔄	📅 timestamp	Mar 10, 2022 @ 11:23:11.924911000
⊕ ⊖ 🔍 🔄	📄 uid	C8D20I2ggQSCXNNZn7
⊕ ⊖ 🔍 🔄	📄 uri	/yTg0Ah6a
⊕ ⊖ 🔍 🔄	📄 user_agent	bitsadmin
⊕ ⊖ 🔍 🔄	# version	3.2

Phase 3: Uncovering the Command and Control (C2) Infrastructure

4. The infected machine connected with a famous filesharing site in this period, which also acts as a C2 server used by the malware authors to communicate. What is the name of the filesharing site?

- **Answer:** pastebin.com
- **Methodology:** Still looking at the logs for the suspicious IP, checking the destination details in the `host` field shows outbound connections being made to pastebin.com, a common site abused by threat actors to host scripts and payloads.

5. What is the full URL of the C2 to which the infected host is connected?

- **Answer:** pastebin.com/yTg0Ah6a
- **Methodology:** To get the exact location of the payload, we combine the domain from the `host` field with the specific path requested found in the `uri` field (`/yTg0Ah6a`).

Mar 1, 2022 @ 00:00:00.000 - Mar 31, 2022 @ 00:00:00.000		
Time ↓	host	uri
> Mar 10, 2022 @ 11:23:11.924911000	pastebin.com	/yTg0Ah6a
> Mar 10, 2022 @ 11:23:11.924911000	pastebin.com	/yTg0Ah6a

Phase 4: Payload Extraction

6. A file was accessed on the filesharing site. What is the name of the file accessed?

- **Answer:** `secret.txt`
- **Methodology:** By safely investigating the discovered C2 URL (<https://pastebin.com/yTg0Ah6a>) in an isolated environment, the resulting web page shows a hosted text file titled `secret.txt`.

7. The file contains a secret code with the format THM{_____}.

- **Answer:** `THM{SECRET__CODE}`
- **Methodology:** Reading the raw text content of the `secret.txt` file hosted on the Pastebin page reveals the final flag, confirming the successful tracking of the attacker's footprint.

